Hunt 02 – Scattered Invoice: BEC Investigation Report

Oct 16, 2026 · @woody

Executive summary

An attacker beat MFA on finance user `m.smith@lognpacific.org` through repeated push prompts, then used his mailbox to send a fraudulent banking-change email inside an existing invoice thread. The bank froze the resulting £24,500 payment. The behaviour is consistent with Scattered Spider (UNC3944 / Octo Tempest), assessed with moderate confidence from TTP overlap.

Item	Finding
Compromised account	`m.smith@lognpacific.org`
Attacker IP	`205.147.16.190`
MFA bypass	MFA fatigue: repeated `50074` challenges, then one approval (`0`)
Attacker session	`00225cfa-a0ff-fb46-a079-5d152fcdf72a` , token issued 21:51:11 UTC
Persistence	Two inbox rules, `.` (forward) and `..` (delete), both `StopProcessingRules = True`
Exfiltration address	`insights@duck.com`
Blast radius	Exchange Online mailbox + Microsoft OneDrive for Business
Financial impact	£24,500 redirected, frozen by the receiving bank (per bank report)
First containment	Revoke sessions

Incident details and scope

The investigation covers one finance account over a three-hour window, using three Microsoft Sentinel tables.

Field	Value
Incident	IR-2026-0225-BEC (Hunt 02 – Scattered Invoice)
Severity	High
Reported	26 Feb 2026, 09:30 UTC, by the external bank's fraud department
Target	LogN Pacific Financial Services, Finance department
Window	25 Feb 2026 21:00 – 26 Feb 2026 00:00 UTC (attacker activity 21:44–22:31)
Platform	Microsoft Sentinel, workspace `law-cyber-range`
Data sources	`SigninLogs`, `CloudAppEvents`, `EmailEvents`
Trigger	User reported repeated MFA prompts on the evening of 25 Feb and approved one; colleagues found unknown inbox rules next morning

Attack timeline (UTC, 25 Feb 2026)

The attacker went from MFA approval to sending the fraudulent email in about 15 minutes, then moved into OneDrive. Rows are in attack order.

Time	Source	Event
21:44	SigninLogs	Attacker activity begins: repeated MFA challenges (`50074`) from 205.147.16.190
21:51:11	CloudAppEvents (AppAccessContext)	Session token issued after Mark approves a push
21:56:24	CloudAppEvents	`MailItemsAccessed` (×3): attacker reads the mailbox

Time	Source	Event
22:02:33	CloudAppEvents	`New-InboxRule` `.` : forward invoice/payment mail to `insights@duck.com`
22:03:59	CloudAppEvents	`New-InboxRule` `..` : delete security-warning mail (86 s after rule 1)
22:04:34	CloudAppEvents	`Create` : BEC reply drafted
22:06:34	CloudAppEvents / EmailEvents	`Send` : fraudulent banking-change email delivered to a finance colleague
22:07:16	CloudAppEvents	SharePoint `SignInEvent` ; OneDrive `FileAccessed`
22:07:18	CloudAppEvents	`ListCreated` (×3), `ListColumnCreated` (×18), `Broke sharing inheritance` (×3)
22:07:23–22:10:10	CloudAppEvents	`ListViewed` , `PageViewed` : browsing OneDrive/SharePoint
22:31	—	End of observed attacker activity

Sentinel displays these times in local time (UTC−5); add 5 hours to convert.

Findings by hunt question

Each hunt prompt and its answer. Values marked *confirm in lab* came from lab queries not captured in these notes.

#	Hunt prompt	Answer
1	Compromised account (UPN as logged)	`m.smith@lognpacific.org`
2	Attacker source IP	`205.147.16.190`
3	ResultType for "MFA required, not completed"	`50074` (decoy: `50140` "Stay signed in?" interrupt)
4	MFA denials before approval (fatigue intensity)	*confirm in lab*: count of `50074` before first `0`

#	Hunt prompt	Answer
5	Minutes between first and second genuine MFA challenge	*confirm in lab*: not a rapid burst
6	Does the sign-in sequence prove the bypass technique?	Proves valid password + MFA satisfied after repeated challenges; does not prove fatigue vs AiTM vs token theft
7	Do logs show where the password came from?	No: sign-in logs record outcomes, not credential origin
8	Inbox rule 1 name	`.`
9	ForwardTo address	`insights@duck.com`
10	Parameter giving rule priority	`StopProcessingRules` (True)
11	Inbox rule 2 name	`..`
12	Seconds between rule creations	86
13	BEC email recipient	*confirm in lab*: finance colleague
14	BEC subject line	*confirm in lab*: begins `RE:` (thread hijack)
15	Evidence boundary: BEC email	Proves the email was sent and delivered; does not prove the recipient acted or funds moved
16	Cloud app accessed	Microsoft OneDrive for Business
17	Session ID linking all activity	`00225cfa-a0ff-fb46-a079-5d152fcdf72a`
18	ConditionalAccessStatus on attacker sign-in	*confirm in lab*: `success` or `notApplied`
19	Account's own second IP: compromised?	Not compromised: normal location/device, no failed MFA (*insert values*)
20	First containment action	Revoke sessions
21	Threat actor	Scattered Spider

Key queries

Sign-in comparison by IP (attacker vs legitimate):

```
SigninLogs
| where TimeGenerated between (datetime(2026-02-25T21:00:00Z) ..
datetime(2026-02-26T00:00:00Z))
| where UserPrincipalName =~ "m.smith@lognpacific.org"
| summarize Success=countif(ResultType == "0"),
            MFA_Challenges=countif(ResultType == "50074"),
            First=min(TimeGenerated), Last=max(TimeGenerated)
            by IPAddress, Country=tostring(LocationDetails.countryOrRegion),
               OS=tostring(DeviceDetail.operatingSystem),
AutonomousSystemNumber
```

MFA denials before approval:

```
let Approval = toscalar(SigninLogs
    | where UserPrincipalName =~ "m.smith@lognpacific.org" and IPAddress ==
"205.147.16.190"
    | where ResultType == "0" | summarize min(TimeGenerated));
SigninLogs
| where TimeGenerated between (datetime(2026-02-25T21:44:00Z) .. Approval)
| where UserPrincipalName =~ "m.smith@lognpacific.org" and IPAddress ==
"205.147.16.190"
| where ResultType == "50074"
| count
```

Inbox rule parameters:

```
CloudAppEvents
| where Timestamp between (datetime(2026-02-25T21:00:00Z) .. datetime(2026-
02-26T00:00:00Z))
| where ActionType == "New-InboxRule" and IPAddress == "205.147.16.190"
| mv-expand Param = parse_json(RawEventData).Parameters
| project Timestamp, Parameter = tostring(Param.Name), Value =
tostring(Param.Value)
```

BEC email:

```
EmailEvents
| where Timestamp between (datetime(2026-02-25T21:00:00Z) .. datetime(2026-02-26T00:00:00Z))
| where SenderFromAddress =~ "m.smith@lognpacific.org" and SenderIPv4 == "205.147.16.190"
| project Timestamp, RecipientEmailAddress, Subject, DeliveryAction
```

Everything the attacker IP did:

```
CloudAppEvents
| where Timestamp between (datetime(2026-02-25T21:00:00Z) .. datetime(2026-02-26T00:00:00Z))
| where IPAddress == "205.147.16.190"
| summarize Count=count(), First=min(Timestamp) by ActionType, Application
| order by First asc
```

Evidence boundaries

Each data source proves one stage of the attack and never the next one.

Evidence	Proves	Does not prove
Sign-in sequence (`50074` … `0`)	Valid password used; MFA satisfied after repeated challenges from attacker IP	That fatigue was the mechanism (AiTM or token theft not excluded)
Sign-in logs generally	Authentication outcomes: result, IP, device, time	How the password was obtained
Inbox rules	Attacker created forward and delete rules under Mark's session	That forwarded mail was read or used by the attacker
EmailEvents	BEC email sent from the compromised mailbox and delivered	What the recipient did with it, or that a payment was made
Bank report	£24,500 redirected and frozen	(External source; the logs alone cannot show it)
OneDrive events	Files accessed; permissions changed	That data was exfiltrated or misused

Evidence	Proves	Does not prove
TTP match	Behaviour consistent with Scattered Spider	Definitive attribution

Indicators of compromise

Block the full forwarding address, not `duck.com`, which is a legitimate email-forwarding service.

Indicator	Type	Pyramid of Pain tier
`205.147.16.190`	Attacker IP	IP address (easy to rotate)
`insights@duck.com`	Exfiltration mailbox	Domain / infrastructure
`00225cfa-a0ff-fb46-a079-5d152fcdf72a`	Attacker session ID	Host / network artefact
Inbox rules `.` and `..`	Persistence	Host artefact
Keywords: invoice, payment, wire, transfer	Forward-rule trigger	Host artefact
Keywords: suspicious, security, phishing, unusual, compromised, verify	Delete-rule trigger	Host artefact
Repeated MFA push until approval	Initial access technique	TTP
Forward + delete rules with `StopProcessingRules`	Defence evasion technique	TTP
Reply into an existing invoice thread	BEC pretext	TTP

Containment and recommendations

Revoke sessions first: a password reset alone leaves the attacker's MFA-satisfied token working.

1. Revoke all sign-in sessions for `m.smith@lognpacific.org` (`Revoke-MgUserSignInSession`)
2. Reset the password
3. Delete inbox rules `.` and `..`
4. Review registered MFA methods and remove any the attacker added
5. Block `insights@duck.com` at the mail gateway; search tenant-wide for other mailboxes forwarding there
6. Alert Finance and the bank about the fraudulent payment instruction
7. Review OneDrive items with broken sharing inheritance and remove external links

Hardening

- Enforce MFA number matching, or phishing-resistant MFA (FIDO2) for finance roles
- Add Conditional Access requiring compliant devices and blocking hosting/anonymous IP ranges
- Require out-of-band verification (a phone call to a known number) for any vendor banking change
- Alert on new inbox rules that forward externally or delete mail

Lessons learned and detection rules

- Scope every query to the incident window and to the identity or IP; tenant-wide tables are noisy.
- Pivot user → IP → session ID → everything that session touched.
- Read `RawEventData` ; summary columns such as `ObjectName` can mislead.
- Not every non-zero ResultType is an MFA push: `50140` is a UI interrupt.
- `summarize` drops columns: add fields to the `by` clause, not a later `project` .
- Baseline the victim's own activity to separate it from the attacker's.
- Write findings as "proves X, does not prove Y".

MFA fatigue detection:

```
SigninLogs
| where TimeGenerated > ago(1h)
| summarize Prompts=countif(ResultType == "50074"),
Success=countif(ResultType == "0")
            by UserPrincipalName, IPAddress, bin(TimeGenerated, 15m)
| where Prompts >= 5 and Success >= 1
```

Suspicious inbox rule detection:

```
CloudAppEvents
| where ActionType in ("New-InboxRule", "Set-InboxRule")
| where RawEventData has "StopProcessingRules"
      and (RawEventData has "ForwardTo" or RawEventData has "DeleteMessage")
| project Timestamp, AccountId, IPAddress, RawEventData
```